التصيد الإلكتروني أو التصيد الاحتيالي أو التصيّد (بالإنجليزية: Phishing) هو محاولة للحصول على معلومات حساسة مثل أسماء المستخدمين وكلمات المرور وتفاصيل بطاقة الائتمان (والأموال)؛ غالبًا لأسباب ضارة، وذلك بالتنكر ككيان جدير بالثقة في اتصال إلكتروني. المصطلح الإنجليزي Phishing هو كلمة مستحدثة أُنشئت باعتبارها مُجَانِسَةً لفظيةً لكلمة fishing التي تعني "صيد الأسماك"؛ بسبب تشابه استخدام الطعم في محاولة للقبض على الضحية. وفقًا لمؤشر أمان الحوسبة في مايكروسوفت لعام 2013، الذي أُصدر في فبراير 2014، قد يصل التأثير العالمي السنوي للتصيد الاحتيالي إلى 5 مليارات دولار أمريكي.

وعادة ما يجري التصيد بها؛ لخداع البريد الإلكتروني أو الرسائل الفورية، وغالباً ما يوجه للمستخدمين الدخول إلى المعلومات الشخصية على موقع على شبكة الإنترنت وهمية، والشكل والمظهر، والتي تكون مطابقة للالشرعية والفرق الوحيد هو عنوان URL للموقع في قلق. الاتصالات قيل أنها من مواقع الشبكة الاجتماعية، مواقع إلكترونية، البنوك، طرق الدفع عبر الإنترنت، وغالباً ما يستخدمها مديري تكنولوجيا المعلومات؛ لجذب الضحايا. قد تحتوي رسائل البريد الإلكتروني التصيدية على روابط إلى مواقع ويب تقوم بتوزيع برامج ضارة.

التصيد هو مثال على تقنيات الهندسة الاجتماعية المستخدمة؛ لخداع المستخدمين، ويستغل نقاط الضعف في أمان الويب الحالي. وتشمل محاولات التعامل مع العدد المتزايد من حوادث التصيد الإلكتروني المبلغ عنها التشريع وتدريب المستخدمين والوعي العام وتدابير الأمن التقني.

أنواع التصيّد الاحتيالي

التصيد الاحتيالي

وقد وصفت محاولات التصيّد الموجهة إلى أفراد أو شركات معينة باسم **التصيد الاحتيالي**. قد يجمع المهاجمون معلومات شخصية عن هدفهم لزيادة احتمالية نجاحهم. هذه التقنية هي الأكثر نجاحًا على الإنترنت اليوم، حيث تمثل 91٪ من الهجمات.

استخدمت مجموعة التهديدات -4127 أساليب التصيد الاحتيالي لاستهداف حسابات البريد الإلكتروني المرتبطة بحملة هيلاري كلينتون الرئاسية لعام 2016. لقد هاجموا أكثر من 1800 حساب في Google ونفذوا account-google.com domain لتهديد المستخدمين المستهدفين.

استنساخ التصيد

يُعد التصيّد الاحتيالي نوعًا من هجمات التصيّد الاحتيالي حيث تم إرسال عنوان بريد إلكتروني شرعي تم تسليمه سابقًا ويحتوي على رابط أو رابط، وتم استخدام عنوانه وعنوانه (عناوين) المتلقي واستخدامهما لإنشاء بريد إلكتروني متطابق تقريبًا أو مستنسخ. يتم استبدال المرفق أو الرابط الموجود في البريد الإلكتروني بإصدار ضار، ثم يتم إرساله من عنوان بريد إلكتروني مزيف ليظهر وكأنه يأتي من المرسل الأصلي. قد يدعي أنه إعادة إرسال النسخة الأصلية أو المحدثة إلى النسخة الأصلية. يمكن استخدام هذه التقنية لتدوير (بشكل غير مباشر) من جهاز مصاب سابقًا والحصول على موطئ قدم على جهاز آخر، وذلك من خلال استغلال الثقة الاجتماعية المرتبطة بالاتصال المستنتج بسبب استلام كلا الطرفين للبريد الإلكتروني الأصلي.

صيد الحيتان

وقد تم توجيه العديد من هجمات التصيد على وجه التحديد إلى كبار المسؤولين التنفيذيين وغيرهم من الأهداف البارزة داخل الشركات، وقد صاغ مصطلح **صيد الحيتان** على هذه الأنواع من الهجمات. في حالة صيد الحيتان، ستأخذ صفحة الويب / البريد الإلكتروني المهزلة شكلاً أكثر جدية من المستوى التنفيذي. سيتم إنشاء المحتوى لاستهداف المدير العلوي ودور الشخص في الشركة. غالبًا ما تتم كتابة محتوى رسالة البريد الإلكتروني الخاصة بهجوم صيد الحيتان على أنها أمر استدعاء قانوني أو شكوى زبون أو قضية تنفيذية. تم تصميم رسائل البريد الإلكتروني احتيالية لصيد الحيتان إلى تنكر باعتبارها بريد إلكتروني الأعمال الهامة، التي أرسلت من سلطة تجارية مشروعة. من المفترض أن يكون المحتوى مخصصًا للإدارة العليا، وعادةً ما ينطوي على نوع من المخاوف المزيفة على مستوى الشركة.وقد قام المحتالون بصيد الحيتان أيضًا بتزوير رسائل البريد الإلكتروني الرسمية لمكتب التحقيقات الفيدرالي (إف بي آي)، وادعى أن المدير يحتاج إلى النقر فوق رابط وتثبيت برنامج خاص لمشاهدة أمر الاستدعاء.

ربط التلاعب

تستخدم معظم أساليب التصيّد الاحتيالي نوعًا من الخداع التقني المصمم لإنشاء رابط في بريد إلكتروني (والموقع الإلكتروني المخادع الذي يؤدي إليه) يبدو أنه ينتمي إلى المنظمة المنتحلة. تمثل عناوين URL التي تحتوي على أخطاء إملائية أو استخدام النطاقات الفرعية حيلًا شائعة يستخدمها المخادعون. في عنوان URL الخاص بالمثال التالي، http://www.yourbank.example.com/ ، يظهر كما لو أن عنوان URL سينقلك إلى قسم *المثال* من موقع الويب الخاص *بشركتك* . في الواقع هذه نقطة URL إلى «*yourbank* قسم» (أي التصيد) من *سبيل المثال* الموقع. من الخدع الشائعة الأخرى إنشاء النص المعروض لرابط (النص بين العلامات) اقتراح وجهة موثوق بها، عندما يذهب الارتباط

فعليًا إلى موقع المخادعين. سيعرض العديد من برامج البريد الإلكتروني لسطح المكتب ومتصفحات الويب عنوان URL المستهدف للرابط في شريط الحالة أثناء تمرير الماوس فوقه. ومع ذلك، قد يتم تجاوز هذا السلوك في بعض الحالات بواسطة المخادع. لا تحتوي تطبيقات الجوال المكافئة عمومًا على ميزة المعاينة هذه.تطبيق محمول

تم العثور على مشكلة أخرى مع عناوين URL في التعامل مع أسماء النطاقات المدولة (IDN) في متصفحات الويب، والتي قد تسمح لعناوين الويب المتطابقة بصريًا بالوصول إلى مواقع ويب مختلفة، وربما ضارة. على الرغم من الدعاية المحيطة بالخلل، والمعروفة باسم هجوم انتحال IDN أو هجوم متجانس، فإن المخادعين قد استفادوا من خطر مماثل، باستخدام معالجات إعادة توجيه عناوين URL المفتوحة على مواقع الويب الخاصة بالمؤسسات الموثوقة لإخفاء عناوين URL الخبيثة مع مجال موثوق به. حتى أن الشهادات الرقمية لا تحل هذه المشكلة لأنه من الممكن تمامًا أن يقوم المخادع بشراء شهادة صالحة وبالتالي تغيير المحتوى لانتحال موقع ويب حقيقي، أو، لاستضافة موقع phish دون SSL على الإطلاق.

تصفية التهرب

حتى أن المخادعين بدأوا في استخدام الصور بدلاً من النص لجعل الأمر أصعب على فلاتر مكافحة الخداع للكشف عن النص المستخدم بشكل شائع في رسائل البريد الإلكتروني المخادعة. ومع ذلك، فقد أدى ذلك إلى تطور المزيد من فلاتر مكافحة الخداع الأكثر تطوراً والقادرة على استرداد النص المخفي في الصور. تستخدم هذه الفلاتر OCR (التعرف الضوئي على الحروف) لمسح الصورة ضوئيًا وتصفيتها ضوئيًا.

حتى أن بعض مرشحات مكافحة الخداع قد استخدمت IWR (التعرّف الذكي على الكلمات)، والذي لا يهدف إلى استبدال OCR تمامًا، ولكن هذه الفلاتر يمكنها حتى الكشف عن مخطوطة أو مكتوبة بخط اليد أو تدويرها (بما في ذلك نص مقلوب) أو مشوهة (مثل جعل النص متموجًا أو ممتدًا رأسيًا أو جانبيًا أو في اتجاهات مختلفة، بالإضافة إلى نص على الخلفيات الملونة.

تزوير الموقع

بمجرد زيارة أحد الضحايا لموقع التصيد الإلكتروني، فإن الخداع لم ينته بعد. تستخدم بعض خدع التصيد الاحتيالي أوامر JavaScript لتغيير شريط العناوين. ويتم ذلك إما عن طريق وضع صورة لعنوان URL شرعي على شريط العناوين، أو عن طريق إغلاق الشريط الأصلي وفتح شريط جديد بعنوان URL شرعي.

يمكن للمهاجم استخدام العيوب في نصوص موقع ويب موثوق به ضد الضحية. هذه الأنواع من الهجمات (المعروفة باسم البرمجة عبر المواقع) هي إشكالية بشكل خاص، لأنها توجه المستخدم لتسجيل الدخول في صفحة الويب الخاصة بالمصرف أو الخدمة الخاصة به، حيث يظهر كل شيء من عنوان الويب إلى شهادات الأمان بشكل صحيح. في الواقع، تم إنشاء رابط الموقع لتنفيذ الهجوم، مما يجعل من الصعب جدًا اكتشافه دون معرفة متخصصة. تم استخدام مثل هذا الخلل في عام 2006 ضد PayPal .

A العالمي الرجل-في منتصف يوفر (MITM) الخداع كيت، الذي اكتشف في عام 2007، واجهة بسيطة الاستخدام التي تسمح للمخادع لإعادة إنتاج مقنع المواقع والتقاط تسجيل الدخول في تفاصيل دخلت في موقع وهمية.

لتجنب تقنيات مكافحة الخداع التي تقوم بمسح مواقع الويب للنص المتعلق بالتصيد الاحتيالي، بدأ المخادعون في استخدام مواقع الويب المستندة على فلاش (تقنية تعرف باسم phlashing). هذه تشبه إلى حد كبير موقع الويب الحقيقي، ولكن إخفاء النص في كائن وسائط متعددة.

إعادة توجيه سرية

إعادة التوجيه السرية هي طريقة خفية لتنفيذ هجمات التصيد الاحتيالي التي تجعل الروابط تبدو مشروعة، ولكن في الواقع إعادة توجيه الضحية إلى موقع المهاجم. عادة ما يتم إخفاء العيب تحت نافذة منبثقة لتسجيل الدخول تستند إلى نطاق الموقع المتأثر. يمكن أن يؤثر ذلك على OAuth 2.0 و OpenID استنادًا إلى معلمات استغلال معروفة جيدًا أيضًا. هذا غالبًا ما يستخدم ثغرات إعادة التوجيه المفتوحة و XSS في مواقع ويب التطبيقات التابعة لجهات خارجية. يمثل التصفح طريقة أخرى لإعادة توجيه المستخدمين إلى مواقع التصيّد الاحتيالي بشكل سري من خلال إضافات المتصفح الضارة.

يمكن أن تكون محاولات الخداع العادية سهلة التعيين لأن عنوان URL للصفحة الخبيثة يكون عادةً مختلفًا عن رابط الموقع الحقيقي. بالنسبة لعملية إعادة التوجيه السرية، يمكن للمهاجم استخدام موقع ويب حقيقي بدلاً من ذلك عن طريق إفساد الموقع باستخدام مربع حوار ضار منبثق لتسجيل الدخول. وهذا يجعل عملية إعادة التوجيه السرية مختلفة عن غيرها.

حتى إذا لم يختار الضحية تفويض التطبيق، فسيظل يتم إعادة توجيهه إلى موقع ويب يسيطر عليه المهاجم. هذا يمكن أن يزيد من خطر الضحية.

تم اكتشاف هذه الثغرة من قبل وانغ جينغ، الدكتوراه في الرياضيات. طالب في كلية العلوم الفيزيائية والرياضية في جامعة نانيانغ التكنولوجية في سنغافورة. تعد إعادة التوجيه السرية عيبًا أمنيًا ملحوظًا، على الرغم من أنها لا تمثل تهديدًا للإنترنت تستحق اهتمامًا كبيرًا.

هندسة اجتماعية

يمكن تشجيع المستخدمين على النقر على أنواع مختلفة من المحتوى غير المتوقع لمجموعة متنوعة من الأسباب الفنية والاجتماعية. على سبيل المثال، قد يتنكر مرفق ضار كمستند حميمي مرتبط في Google .

بدلاً من ذلك، قد يشعر المستخدمون بالغضب بسبب قصة إخبارية مزيفة، والنقر على رابط وتصيبهم بالعدوى.

التصيد عبر الهاتف

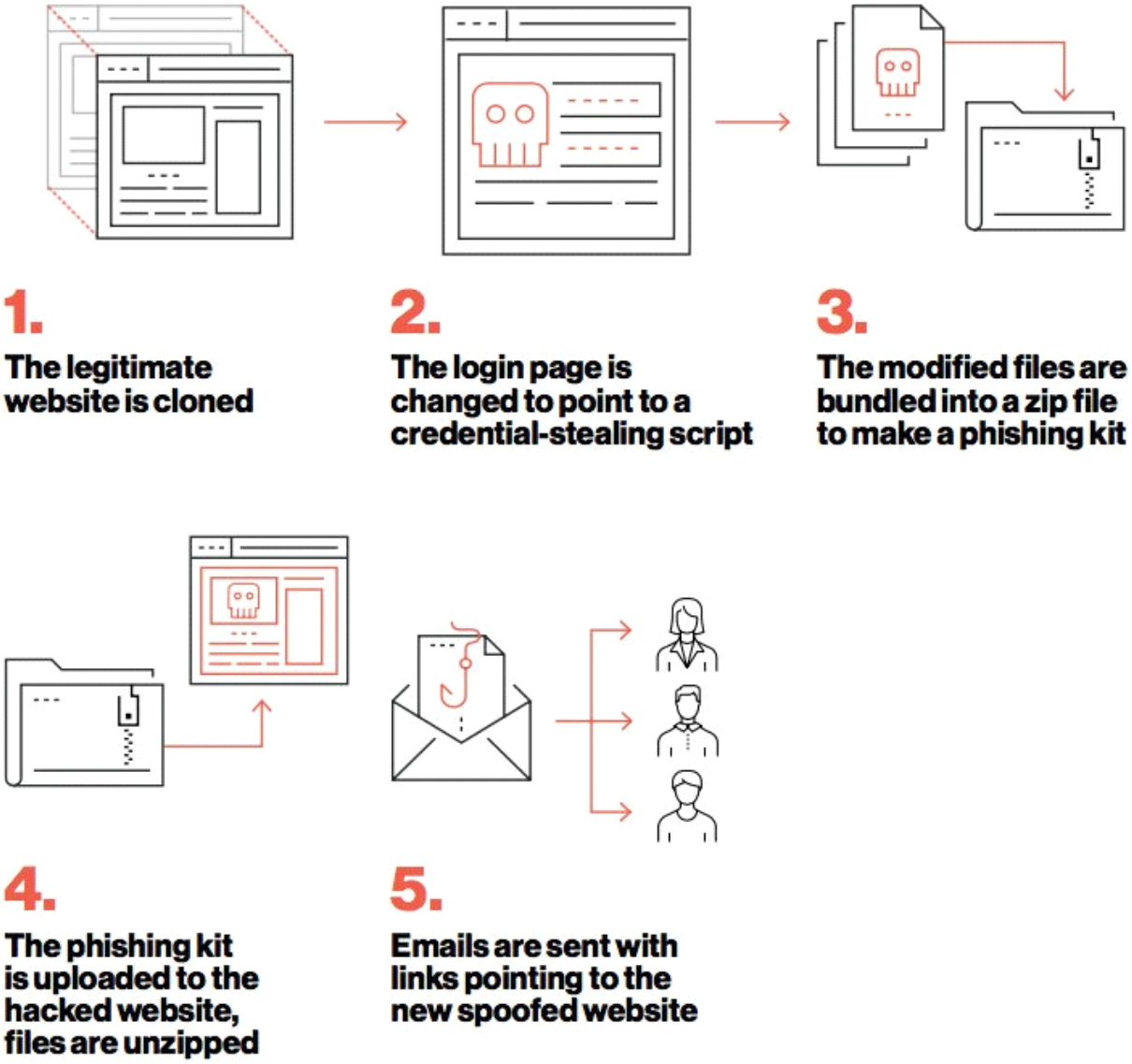
لا تتطلب جميع هجمات التصيد الاحتيالي وجود موقع ويب مزيف. طلبت الرسائل التي ادعت أنها من أحد المصارف من المستخدمين طلب رقم هاتف يتعلق بمشكلات في حساباتهم المصرفية. بمجرد الاتصال برقم الهاتف (المملوك من قبل المخادع، وتوفيره عبر خدمة الصوت عبر الإنترنت)، تطلب مطالبات المستخدمين إدخال أرقام حساباتهم ورقم تعريف شخصي. أحيانًا ما يستخدم Vishing (التصيد الصوتي) بيانات هوية المتصل المزيفة لإعطاء المظهر الذي تأتيه المكالمات من مؤسسة موثوق بها. يستخدم التصيد عبر الرسائل النصية القصيرة رسائل نصية للهواتف المحمولة لحث الناس على الإفصاح عن معلوماتهم الشخصية.

تقنيات أخرى

- هجوم آخر تم استخدامه بنجاح هو إعادة توجيه العميل إلى الموقع الشرعي للبنك، ثم وضع نافذة منبثقة تطلب بيانات الاعتماد أعلى الصفحة بطريقة تجعل العديد من المستخدمين يعتقدون أن البنك يطلب هذه المعلومات الحساسة.

- يستفيد Tab nabbing من الاستعراض المبوب، مع علامات تبويب متعددة مفتوحة. تعيد هذه الطريقة بصمت توجيه المستخدم إلى الموقع المتأثر. تعمل هذه التقنية عكسًا لمعظم تقنيات التصيد الاحتيالي من حيث أنها لا تنقل المستخدم مباشرة إلى الموقع الاحتيالي، وإنما تحمّل الصفحة المزوّرة في إحدى علامات التبويب المفتوحة في المتصفح.

- Evil twin هي تقنية تصيد احتيالي يصعب اكتشافها. يخلق المخادع شبكة لاسلكية مزيفة تشبه شبكة عامة شرعية يمكن العثور عليها في الأماكن العامة مثل المطارات أو الفنادق أو المقاهي. عندما يسجل شخص ما الدخول إلى الشبكة الزائفة، يحاول المحتالون التقاط كلمات المرور الخاصة بهم و / أو معلومات بطاقة الائتمان الخاصة بهم.



ما هو برنامج الفدية كخدمة (Ransomware as a Service)؟

"Ransomware as a Service (RaaS)" هو نموذج عمل قائم على الاشتراك حيث يقوم المجرمون الإلكترونيون بتطوير وبيع أو تأجير أدوات الفدية والبنية التحتية لجهات فاعلة أخرى تُسمى "المتعاونين" مقابل حصة من الأرباح. لقد

أدى ذلك إلى "ديمقراطية" الجرائم الإلكترونية من خلال تمكين الأفراد ذوي المهارات التقنية المحدودة من تنفيذ هجمات فدية معقدة، مما أدى إلى زيادة هائلة في الحوادث.

نموذج RaaS يحاكي نموذج البرمجيات كخدمة، مع حملات تسويقية، مراجعات من المستخدمين، دعم على مدار الساعة، وبوابات إلكترونية لتتبع الإصابات والمدفوعات.

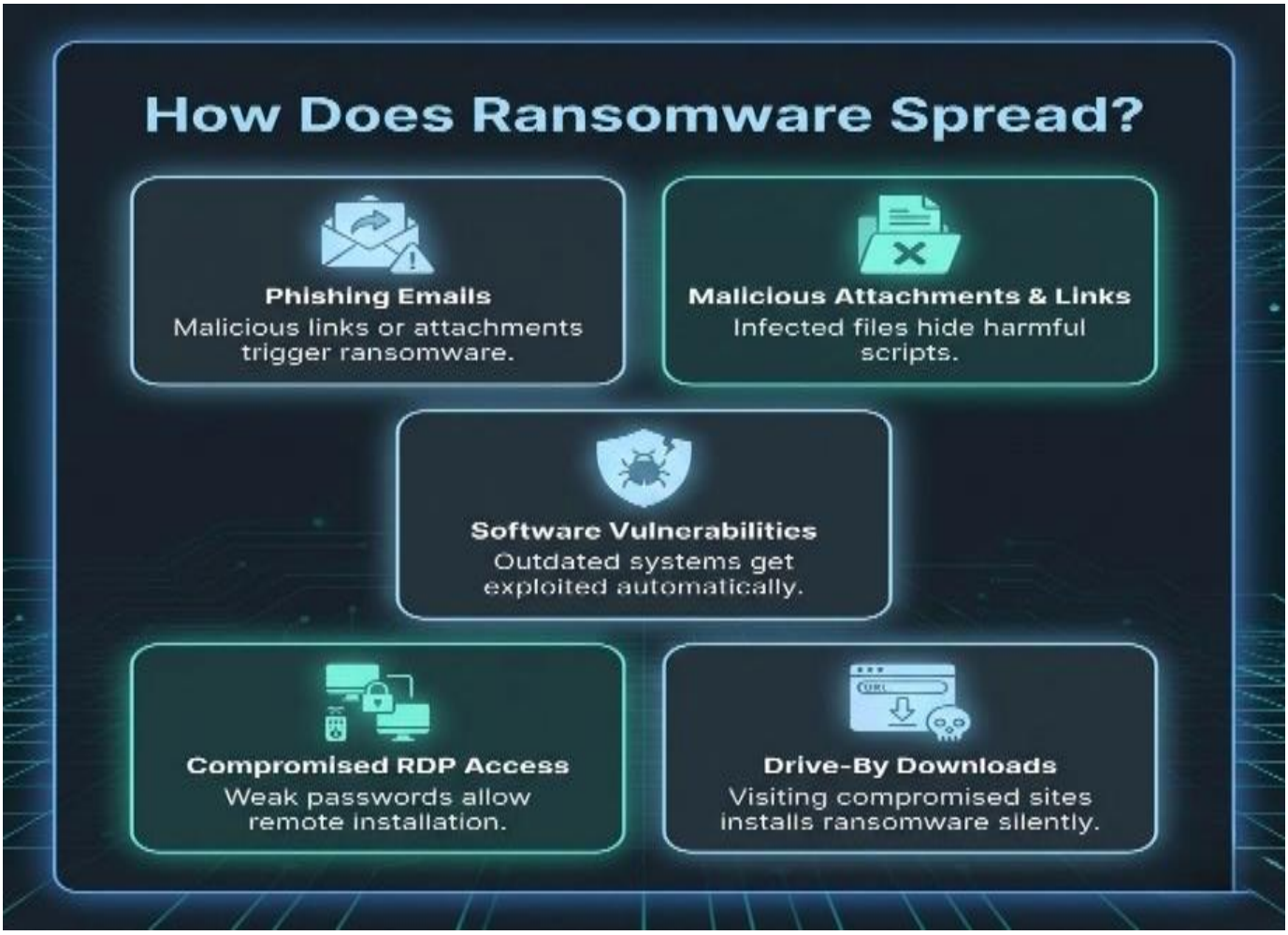
تشمل هجمات RaaS تعاون عدة فاعلين تهديد.

- **مشغلو RaaS (المطورون):** إنشاء وصيانة البرمجيات الخبيثة الخاصة بالفدية، والبنية التحتية (مثل خوادم القيادة والتحكم)، وأنظمة الدفع. يتعاملون مع الجوانب التقنية ويعلنون عن مجموعات RaaS الخاصة بهم في منتديات الويب المظلم.
- **شركاء RaaS:** شراء أو استئجار الوصول إلى مجموعات برامج الفدية من المشغلين. هم مسؤولون عن توزيع البرمجيات الخبيثة على الضحايا، عادةً من خلال طرق مثل رسائل البريد الإلكتروني الاحتيالية، استغلال ثغرات البرمجيات، أو الهندسة الاجتماعية.
- **وسطاء الوصول الأولي:** تتضمن بعض عمليات RaaS المتقدمة أيضًا طرفًا ثالثًا متخصصًا في اختراق الشبكات المؤسسية وبيع الوصول إلى الشركات التابعة.
- **تقسيم الأرباح:** إذا دفع الضحية، يحصل مشغلو RaaS على حصتهم، ويحصل الشريك على الباقي. نسبة تقسيم الأرباح الشائعة تعطي الشريك أغلبية كبيرة (على سبيل المثال، 70-80%) من الفدية.

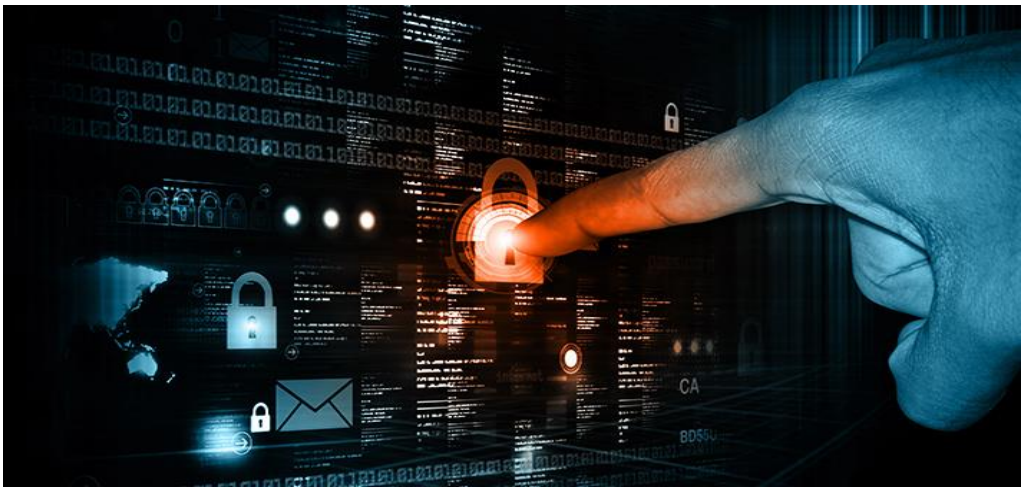
يستخدم المجرمون الإلكترونيون عدة نماذج أعمال وأساليب ابتزاز لزيادة أرباحهم.

- **الاشتراك:** رسوم شهرية ثابتة للوصول إلى برنامج الفدية.
- **برنامج الشراكة:** رسوم شهرية بالإضافة إلى نسبة من أي مدفوعات فدية ناجحة.
- **رسوم ترخيص لمرة واحدة:** دفعة واحدة مقابل الوصول غير المحدود.
- **مشاركة الأرباح:** لا توجد تكلفة مسبقة، ولكن المطور يأخذ حصة أكبر من الفدية.

- **الابتزاز المزدوج:** أسلوب جديد حيث يقوم المهاجمون بتشفير بيانات الضحية وسرقتها. يهددون بنشر المعلومات الحساسة على "موقع تسريب" عام إذا لم يتم دفع الفدية، مما يزيد الضغط على الضحية.
- **الابتزاز الثلاثي:** تصعيد للابتزاز المزدوج يتضمن عنصرًا ثالثًا، مثل هجوم حجب الخدمة الموزع (DDoS) على موقع الضحية أو بنيتها التحتية لزيادة الضغط.



ما المقصود بهجوم موزع لحجب الخدمة (DDoS)



هناك العديد من التهديدات الإلكترونية التي يجب على مستخدمي الإنترنت ومسؤولي الشبكات الحذر منها، ولكن بالنسبة للمؤسسات التي تعمل خدماتها إلى حد كبير عبر الإنترنت، فإن أحد أهم الهجمات التي يجب الانتباه إليها، نظرًا لانتشارها المتزايد - هو هجمات رفض الخدمة الموزعة (DDoS). ولكن ما هو هجوم رفض الخدمة، وكيف يعمل، وهل هناك طرق لمنعه؟

هجمات حجب الخدمة الموزعة (DDoS)

ا هي هجمات DDoS؟ ويستفيد هذا النوع من الهجمات من حدود القدرة الخاصة التي تنطبق على أي موارد للشبكة، مثل البنية التحتية التي تمكّن موقع ويب للشركة. سترسل هجمات DDoS طلبات متعددة إلى مورد الويب الذي تمت مهاجمته، بهدف تجاوز قدرة موقع الويب على معالجة الطلبات المتعددة... وبالتالي منعه من العمل بشكل صحيح. تتضمن الأهداف النموذجية لهجمات DDoS مواقع التجارة الإلكترونية وأي منظمة تقدم خدمات عبر الإنترنت.

كيف يعمل؟

إن الجزء الأساسي من فهم هجمات DDoS هو معرفة كيفية عمل هذه الهجمات. تخضع موارد الشبكة، مثل خوادم الويب، لحدود معينة لجهة عدد الطلبات التي يمكن خدمتها في آن واحد. وبالإضافة إلى حدود قدرة الخادم، سيكون للقناة التي تربط الخادم بالإنترنت نطاق تردد / قدرة محدودة أيضًا. ومتى تجاوز عدد الطلبات حدود قدرة أي مكون من مكونات البنية التحتية، من المحتمل أن يتراجع مستوى الخدمة كما يلي:

عادةً، يكون هدف المهاجم في أي مثال لهجوم DDoS هو إغراق خادم موارد الويب، ومنع الوظيفة الطبيعية مما يؤدي إلى رفض الخدمة بالكامل. وقد يطلب المتطفل أيضًا المال مقابل إيقاف الهجوم. وفي بعض الحالات قد يكون هجوم DDoS بهدف محاولة تشويه سمعة أعمال أحد المنافسين أو الإضرار بها.

لتنفيذ الهجوم، يقوم المهاجم بالاستيلاء على السيطرة على شبكة أو جهاز عن طريق إصابته بالبرمجيات الخبيثة ، مما يؤدي إلى إنشاء شبكة بوت نت . ثم يقومون ببدء الهجوم عن طريق إرسال تعليمات محددة إلى الروبوتات. وبدوره، يبدأ الروبوت في إرسال الطلبات إلى الخادم المستهدف من خلال عنوان IP الخاص به، مما يؤدي إلى إغراق الخادم وتسبب في رفض الخدمة لحركة المرور العادية الخاصة به.

أمثلة على هجوم DDoS: ما هي أنواع الهجمات المختلفة؟

إن تعلم معنى هجمات DDoS وكيفية عمل هذه الهجمات هو خطوة واحدة في منعها، ولكن من المهم أيضًا فهم أن هناك أنواعًا مختلفة من هجمات DDoS. يعتمد هذا أولاً على تحديد كيفية تشكيل اتصالات الشبكة.

يحدد نموذج الربط بين الأنظمة المفتوحة (OSI)، الذي طورته المنظمة الدولية للمعايير، سبع طبقات مميزة تشكل اتصالات شبكة الإنترنت. وتشمل هذه الطبقات الطبقة المادية، وطبقة ارتباط البيانات، وطبقة الشبكة، وطبقة النقل، وطبقة الجلسة، وطبقة العرض، وطبقة التطبيق.

تختلف أمثلة هجمات DDoS العديدة حسب طبقة الاتصال التي تستهدفها. وفيما يلي بعض الأمثلة الأكثر شيوعًا.

هجمات طبقة التطبيقات

يُطلق عليها أحيانًا اسم هجوم الطبقة 7 (لأنها تستهدف الطبقة السابعة (التطبيق) من نموذج OSI)، وتستنفد هذه الهجمات موارد الخادم المستهدف باستخدام مواقع الويب DDoS. الطبقة السابعة هي الطبقة التي يقوم فيها الخادم بإنشاء صفحات الويب استجابة لطلب HTTP. يقوم المهاجمون بتنفيذ عدد كبير من طلبات HTTP، مما يؤدي إلى إرهاق الخادم المستهدف أثناء استجابته عن طريق تحميل العديد من الملفات وتشغيل استعلامات قاعدة البيانات المطلوبة لإنشاء صفحة ويب.

فيضان HTTP

يمكنك أن تفكر في هجمات DDoS هذه على أنها تحديث متصفح الويب عدة مرات على العديد من أجهزة الكمبيوتر. يؤدي هذا إلى إنشاء "طوفان" من طلبات HTTP، مما يفرض رفض الخدمة. يمكن أن يكون تنفيذ هذه الهجمات بسيطًا - باستخدام عنوان URL واحد مع نطاق ضيق من عناوين IP - أو معقدًا، باستخدام مجموعة من عناوين IP وعناوين URL العشوائية.

هجمات البروتوكول

تُسمى هذه الهجمات غالبًا بهجمات استنفاد الحالة، وهي تستغل الثغرات الأمنية في الطبقتين الثالثة والرابعة من نموذج OSI (طبقات الشبكة والنقل). تؤدي هذه الهجمات إلى إنشاء حالة رفض للخدمة من خلال إرهاق موارد الخادم أو موارد معدات الشبكة، مثل جدران الحماية . هناك عدة أنواع من هجمات البروتوكول، بما في ذلك فيضانات SYN. تستغل هذه البرامج مصافحة TCP (بروتوكول التحكم في الإرسال)، والتي تسمح لشخصين بإنشاء اتصال بالشبكة، وإرسال عدد غير قابل للإدارة من "طلبات الاتصال الأولية" TCP من عناوين IP وهمية.

الهجمات الحجمية

تؤدي أمثلة هجوم DDoS هذه إلى إنشاء عملية رفض الخدمة عن طريق استخدام كل النطاق الترددي المتاح على خادم مستهدف عن طريق إرسال كميات هائلة من البيانات لإنشاء زيادة في حركة المرور على الخادم.

تضخيم DNS

هذا هجوم قائم على الانعكاس حيث يتم إرسال طلب إلى خادم DNS من عنوان IP مزيف (عنوان الخادم المستهدف)، مما يدفع خادم DNS إلى "الاتصال" بالهدف للتحقق من الطلب. يتم تضخيم هذا الإجراء باستخدام شبكة بوت نت، مما يؤدي إلى إغراق موارد الخادم المستهدف بسرعة.

تحديد هجوم DDoS

قد يكون من الصعب تحديد هجمات DDoS لأنها قد تحاكي مشكلات الخدمة التقليدية وتصبح أكثر تعقيدًا بشكل متزايد. ومع ذلك، هناك بعض العلامات التي قد تشير إلى أن النظام أو الشبكة قد أصبحت ضحية لهجوم DDoS. وتشمل بعض هذه الجوانب ما يلي:

- زيادة مفاجئة في حركة المرور الناتجة عن عنوان IP غير معروف

- تدفق كبير من حركة المرور من العديد من المستخدمين الذين يتشاركون أوجه تشابه محددة، مثل الموقع الجغرافي أو إصدار متصفح الويب
- زيادة غير مبررة في الطلبات على صفحة واحدة
- أنماط حركة المرور غير العادية
- أداء الشبكة بطيء
- خدمة أو موقع ويب يتوقف فجأة عن العمل دون سبب

منع هجمات DDoS والتخفيف منها

على الرغم من أن هجمات الحرمان من الخدمة الموزعة قد يكون من الصعب اكتشافها، فمن الممكن تنفيذ العديد من التدابير لمحاولة منع هذه الأنواع من الهجمات الإلكترونية والتخفيف من أي ضرر في حالة وقوع هجوم. بالنسبة للمستخدمين الذين يتساءلون عن كيفية منع هجمات DDoS، فإن المفتاح هو إنشاء خطة عمل لتأمين الأنظمة والتخفيف من الأضرار في حالة وقوع هجوم. بشكل عام، من المفيد تنفيذ حل مثل حماية Kaspersky DDoS للشركات، والذي يقوم بتحليل وإعادة توجيه حركة المرور الضارة بشكل مستمر. بالإضافة إلى ذلك، يمكن للنصائح العامة التالية أن تساعدك على تعزيز دفاعاتك بشكل أكبر:

- تقييم إعدادات النظام الحالية - بما في ذلك البرامج والأجهزة والخوادم والشبكات - لتحديد المخاطر الأمنية والتهديدات المحتملة، ثم تنفيذ التدابير للحد منها؛ إجراء تقييمات منتظمة للمخاطر.
- احرص على تحديث كافة البرامج والتقنيات للتأكد من تشغيل أحدث تصحيحات الأمان عليها.
- تطوير استراتيجية قابلة للتطبيق للوقاية من هجمات الحرمان من الخدمة الموزعة (DDoS) واكتشافها والتخفيف من حدتها.
- تأكد من أن أي شخص مشارك في خطة منع الهجوم يفهم معنى هجوم DDoS والأدوار المخصصة له.

في حالة وقوع هجوم، قد توفر الإجراءات التالية بعض التخفيف:

- **شبكات Anycas:** إن استخدام شبكة Anycast لإعادة توزيع حركة المرور يمكن أن يساعد في الحفاظ على قابلية استخدام الخادم أثناء معالجة المشكلة، مما يضمن عدم الحاجة إلى إيقاف تشغيل الخادم بالكامل.

- **توجيه الثقب الأسود:** في هذا السيناريو، يقوم مسؤول الشبكة لدى مزود خدمة الإنترنت بإعادة توجيه كل حركة المرور من الخادم المستهدف إلى مسار الثقب الأسود (عنوان IP المستهدف)، مما يؤدي إلى إسقاطه من الشبكة والحفاظ على سلامته. ومع ذلك، قد تكون هذه خطوة متطرفة، لأنها تمنع أيضًا حركة المرور المشروعة.

- **تحديد المعدل:** يحدد هذا عدد الطلبات التي يمكن للخادم قبولها في أي وقت. ورغم أنها لن تكون فعالة للغاية بمفردها، إلا أنها قد تكون مفيدة كجزء من استراتيجية أكبر.

- **جدران الحماية:** يمكن للمؤسسات استخدام جدران حماية تطبيقات الويب (WAF) لتكون بمثابة وكيل عكسي لحماية خوادمها. يمكن إعداد جدران حماية التطبيقات (WAFs) باستخدام قواعد لتصفية حركة المرور، ويمكن للمسؤولين تعديل ذلك في الوقت الفعلي إذا اشتبهوا في وقوع هجوم DDoS.

هجوم الرجل الوسيط

ما هو الهجوم الوسيط في الأمن السيبراني؟

حدث **هجوم الرجل في الوسط (MITM)** عندما يعترض المهاجم بهدوء الاتصال بين طرفين (متصفح المستخدم وخادم الموقع الإلكتروني) ويغيره دون علم أي من الطرفين. يمكن لهذا النوع من الهجمات الإلكترونية أن يخترق البيانات الحساسة، مثل بيانات اعتماد تسجيل الدخول أو المعلومات الشخصية أو التفاصيل المالية، دون علم الضحية. في الأساس، يقوم المهاجم بإقحام نفسه في تدفق الاتصالات، ويحصل على وصول غير مصرح به إلى المعلومات المتبادلة.

يمكن أن تحدث هجمات MITM بطرق مختلفة، باستخدام تقنيات مختلفة لخداع الضحايا والوصول إلى بياناتهم. على سبيل المثال، قد يستغل أحد المهاجمين نقاط الضعف في بروتوكولات الشبكة، أو يتلاعب بسجلات DNS، أو يعترض الاتصالات على شبكة Wi-Fi عامة غير آمنة. إن فهم كيفية عمل هذه الهجمات، بالإضافة إلى أنواعها وتقنياتها المختلفة، يمكن أن يساعد في الحد من مخاطرها.

كيف يعمل هجوم الرجل في الوسط؟

يتبع هجوم MITM ثلاث مراحل: الاعتراض وفك التشفير والتلاعب بالبيانات. على سبيل المثال، يمكن للمهاجم تغيير التفاصيل المصرفية أثناء إجراء معاملة مصرفية عبر الإنترنت، وإعادة توجيه الأموال إلى حسابه. وفيما يلي شرح مفصّل لكيفية عملها:

1. **الاعتراض**: تتمثل الخطوة الأولى لهجوم MITM في اعتراض الاتصال بين طرفين. ويمكن تحقيق ذلك من خلال عدة طرق:
   - **الانتحال**: قد يستخدم المهاجم انتحال عنوان IP أو MAC لانتحال شخصية جهاز أو خادم موثوق به. من خلال التظاهر بأنه مشارك شرعي في الاتصال، يمكن للمهاجم اعتراض البيانات الموجهة إلى المستلم الفعلي.
   - **نقاط الوصول المارقة**: قد يقوم أحد المهاجمين بإعداد شبكة Wi-Fi مخادعة باسم مشابه لشبكة شرعية. يقوم المستخدمون المتصلون بهذه الشبكة المارقة بتوجيه حركة مرور الإنترنت الخاصة بهم عبر النظام دون علمهم.
   - **انتحال ARP**: ينطوي انتحال بروتوكول حل العناوين (ARP) على إرسال رسائل ARP مزيفة على شبكة محلية. هذا الإجراء يربك الأجهزة على الشبكة ويجعلها ترسل بياناتها إلى المهاجم بدلاً من الوجهة المقصودة.

2. **فك التشفير:** إذا كانت البيانات المعترضة مشفرة، يحتاج المهاجم إلى فك تشفيرها لجعلها قابلة للقراءة. يمكنهم استخدام الطرق التالية:

- **تجريد SSL**: يؤدي خفض مستوى اتصال HTTPS الآمن إلى HTTP غير المشفر إلى HTTP غير المشفر إلى إمكانية قراءة البيانات بنص عادي.
- **رجل داخل المتصفح**: يمكن للبرمجيات الخبيثة اعتراض البيانات وتعديلها مباشرةً داخل المتصفح قبل تشفيرها، والتقاط المعلومات الحساسة حتى لو كانت مفعّلة باستخدام بروتوكول SSL.

3. **التلاعب بالبيانات:** بمجرد أن يتمكن المهاجم من الوصول إلى البيانات، يمكنه التلاعب بها بالطريقة التالية:

- **اختطاف الجلسة**: السيطرة على جلسة عمل نشطة عن طريق سرقة رموز الجلسة، مما يسمح للمهاجم بتنفيذ إجراءات كما لو كان هو المستخدم الشرعي.
- **حقن البيانات**: تغيير البيانات التي يتم إرسالها أو استلامها، مثل تغيير وجهة التحويل المصرفي أو تعديل محتوى رسالة بريد إلكتروني.

أنواع هجمات الرجل في المنتصف

تستغل عدة أنواع من هجمات MITM جوانب مختلفة من اتصالات الشبكة وأمنها:

1 . التنصت على الواي فاي

يحدث **التنصت على شبكة Wi-Fi** عندما يعترض المهاجمون البيانات المرسلة عبر شبكة لاسلكية. وهو تهديد شائع في البيئات التي تحتوي على شبكة Wi-Fi عامة، حيث يكون أمان الشبكة متراخيًا في كثير من الأحيان. يمكن للمهاجمين استخدام أدوات لالتقاط حزم البيانات غير المشفرة، بما في ذلك بيانات اعتماد تسجيل الدخول والمعلومات المالية وغيرها من التفاصيل الشخصية.

مثال: يقوم أحد المهاجمين بإعداد نقطة اتصال Wi-Fi باسم "Wi-Fi مجاني" في مكان عام. عندما يتصل المستخدمون بنقطة الاتصال هذه، يمكن للمهاجم مراقبة نشاطهم على الإنترنت، بما في ذلك المعلومات المالية وبيانات اعتماد تسجيل الدخول.

لإجراء عمليات التنصت على شبكة Wi-Fi، يستخدم المهاجمون أدوات مثل Wireshark أو Ettercap لمراقبة حركة مرور البيانات على الشبكة. يمكن لهذه الأدوات تحليل حزم البيانات المتبادلة بين الأجهزة على الشبكة، مما يسمح للمهاجم باستخراج البيانات غير المشفرة.

2. انتحال نظام أسماء النطاقات

ينطوي **انتحال** نظام أسماء النطاقات أو **تسميم ذاكرة التخزين المؤقت** لنظام أسماء النطاقات على إفساد ذاكرة التخزين المؤقت لمحلل نظام أسماء النطاقات لإعادة توجيه المستخدمين إلى مواقع ويب خبيثة. من خلال إدراج سجلات DNS زائفة، يمكن للمهاجمين إعادة توجيه حركة المرور المخصصة للمواقع الشرعية إلى مواقع ويب مزيفة تحاكي مظهر المواقع الحقيقية.

مثال: يقوم أحد المهاجمين بتلويث ذاكرة التخزين المؤقت لنظام أسماء النطاقات DNS لشبكة إحدى الشركات، ويعيد توجيه المستخدمين إلى موقع مصرفي مزيف يبدو مطابقًا للموقع الحقيقي. عندما يدخل المستخدمون تفاصيل تسجيل الدخول الخاصة بهم، يلتقطها المهاجم.

3. انتحال HTTPS (اختطاف SSL)

انتحال HTTPS أو اختطاف SSL هو اعتراض اتصالات HTTPS الآمنة والتلاعب بها. قد يستخدم المهاجمون تجريد SSL لخفض مستوى الاتصال من HTTPS إلى HTTP، مما يجعل البيانات قابلة للقراءة.

مثال: يقوم أحد المهاجمين باعتراض اتصال المستخدم بموقع مصرفي عبر الإنترنت ويستخدم تجريد SSL لتحويل اتصال HTTPS إلى HTTP. يمكن للمهاجم بعد ذلك قراءة معلومات حساسة، مثل تفاصيل الحساب المصرفي.

غالبًا ما يتضمن اختطاف SSL اعتراض المصافحة الأولية لاتصال HTTPS. يمكن للمهاجمين بعد ذلك تقديم شهادة SSL احتيالية، وإقناع المتصفح بإنشاء اتصال غير مشفر.**4. الانتحال عبر بروتوكول الإنترنت**

أثناء **انتحال بروتوكول الإنترنت IP**، يتظاهر المهاجمون بأنهم كيان موثوق به من خلال تزوير عنوان IP المصدر في حزم البيانات. يمكن لهذه التقنية اعتراض أو إعادة توجيه حركة المرور أو القيام بأنشطة أخرى غير شريفة.

مثال: يستخدم أحد المهاجمين انتحال عنوان IP لإخفاء عنوان IP الخاص به على أنه خادم موثوق به، مما يؤدي إلى اعتراض حركة المرور المخصصة للخادم الشرعي ويؤدي إلى وصول غير مصرح به أو سرقة البيانات.

يقوم انتحال عنوان IP بتغيير عنوان المصدر في حزم IP. يستخدم المهاجمون أدوات لتزوير رؤوس عناوين IP، مما يجعل حركة المرور تبدو وكأنها قادمة من مصدر شرعي. وهذا يسمح لهم بتجاوز آليات المصادقة القائمة على بروتوكول الإنترنت.

5. اختطاف البريد الإلكتروني

اختطاف البريد الإلكتروني عندما يحصل المهاجمون على وصول غير مصرح به إلى حساب بريد إلكتروني. وغالباً ما يستخدمون التصيد الاحتيالي أو البرمجيات الخبيثة لمراقبة اتصالات البريد الإلكتروني والتلاعب بها. وبمجرد وصولهم إلى الحساب، يمكنهم قراءة الرسائل وإرسالها وتغييرها دون علم المستخدم الشرعي. قد يستخدم القراصنة البريد الإلكتروني المخترق لسرقة معلومات حساسة أو انتحال شخصية المستخدم أو ارتكاب عمليات احتيال.

مثال: يحصل أحد المهاجمين على إمكانية الوصول إلى حساب بريد إلكتروني ويرسل رسائل بريد إلكتروني تصيدية إلى جهات اتصال المستخدم، ويخدعهم لدفع فواتير مزيفة إلى حساب مصرفي احتيالي.

التقنيات المستخدمة في هجمات الرجل في الوسيط

يستخدم المخترقون العديد من التقنيات المتطورة لتنفيذ هجمات MITM:

- **استنشاق الحزم:** يتضمن التقاط حزم البيانات وتحليلها أثناء انتقالها عبر الشبكة. ويستخدم المهاجمون مستنشقو الحزم لاعتراض وفحص البيانات غير المشفرة، والتي قد تتضمن معلومات حساسة مثل أسماء المستخدمين وكلمات المرور والرسائل الشخصية.
- **اختطاف الجلسة:** يحدث هذا عندما يتحكم أحد المهاجمين في جلسة مستخدم نشطة عن طريق سرقة رموز أو معرّفات الجلسة. وبمجرد السيطرة عليها، يمكنهم تنفيذ إجراءات نيابةً عن المستخدم، مثل تحويل الأموال أو تغيير إعدادات الحساب.

- **تجريد SSL:** تقنية يقوم فيها المهاجم بتخفيض مستوى اتصال HTTPS الآمن إلى اتصال HTTP غير مشفر. وبهذه الطريقة، يعترضون ويقرأون بيانات حساسة ومشفرة.

- **هجمات التوأم الشرير** يحدث هجوم التوأم الشرير عندما يقوم أحد المخترقين بإعداد شبكة Wi-Fi مزيفة تبدو مثل الشبكة الحقيقية. عندما يتصل الأشخاص بهذه الشبكة المزيفة، يستطيع المخترق رؤية وسرقة جميع المعلومات المرسلة من أجهزتهم. يأتي اسم "التوأم الشرير" من حقيقة أن هذه الشبكة المزيفة تتظاهر بأنها موثوقة ولكنها مصممة لخداع الناس وسرقة معلوماتهم.

لماذا تعتبر هجمات الرجل في الوسط خطيرة؟

يشكل هجوم الرجل في الوسط بعض المخاطر الكبيرة:

1. **سرقة البيانات:** يمكن أن تؤدي هجمات MITM إلى سرقة معلومات حساسة مثل بيانات اعتماد تسجيل الدخول والتفاصيل المالية والبيانات الشخصية. يمكن للمهاجمين استخدام هذه المعلومات لسرقة الهوية أو الاحتيال المالي أو غيرها من الأنشطة الخبيثة.

2. **التلاعب بالبيانات:** يمكن للمهاجمين تغيير البيانات المرسلة، مما قد يؤدي إلى معاملات خاطئة أو تغييرات غير مصرح بها أو معلومات خاطئة. يمكن أن يؤدي ذلك إلى تقويض سلامة الاتصالات والمعاملات.

3. **فقدان الخصوصية**: يمكن أن تؤدي القدرة على اعتراض الاتصالات وقراءتها إلى فقدان خصوصية الأفراد والمؤسسات. يمكن للمهاجمين مراقبة الرسائل الشخصية ورسائل البريد الإلكتروني وغيرها من المعلومات السرية.

4. **الإضرار بالسمعة**: بالنسبة للشركات، يمكن أن يؤدي وقوعها ضحية لهجوم MITM إلى الإضرار بسمعتها وتقويض ثقة العملاء. قد يفقد العملاء والعملاء الثقة في قدرة الشركة على حماية بياناتهم.

5. **العواقب القانونية**: قد تواجه المؤسسات التي تفشل في الحماية من هجمات MITM مشاكل قانونية، بما في ذلك الغرامات والعقوبات لعدم الامتثال للوائح حماية البيانات.

كيفية اكتشاف هجوم الرجل في المنتصف

قد يكون اكتشاف هجمات MITM أمرًا صعبًا، ولكن هناك العديد من المؤشرات التي يجب البحث عنها:

1. **نشاط غير عادي على الشبكة**: يمكن لأدوات المراقبة أن تكتشف أنماط حركة مرور غير اعتيادية أو عمليات نقل بيانات غير متوقعة، مما قد يشير إلى وجود مهاجمين من MITM.

2. **تحذيرات الشهادات**: ستعرض المتصفحات والتطبيقات تحذيرات إذا اكتشفت وجود مشكلات في شهادات SSL/TLS. يمكن أن تشير هذه التحذيرات إلى أن الاتصال الآمن يتعرض للخطر.

3. **مطالبات غير متوقعة لتسجيل الدخول**: إذا طُلب من المستخدمين إدخال بيانات الاعتماد الخاصة بهم على موقع ويب مزيف أو نافذة منبثقة غير متوقعة، فقد يكون ذلك علامة على هجوم MITM.

4. **أخطاء الاتصال**: يمكن أن تشير أخطاء الاتصال المتكررة أو التغييرات في تكوين الشبكة إلى هجوم MITM. على سبيل المثال، قد يؤدي تجريد SSL إلى فشل الاتصالات الآمنة أو العودة إلى HTTP غير المشفر.

5. **سلوك غير عادي**: قد تعني إعدادات الحساب أو المعاملات أو التغييرات غير المتوقعة في الحساب أو الاتصالات أن أحد المهاجمين قد سيطر على جلسة المستخدم.

كيفية منع هجوم الرجل في المنتصف

يتمحور منع هجمات MITM حول اتخاذ تدابير وممارسات أمنية استباقية وتنفيذ تدابير وممارسات أمنية منطقية:

1. **استخدم اتصالات مشفرة**: استخدم دائمًا **HTTPS** للاتصال الآمن. تأكد من أن مواقع الويب والتطبيقات تستخدم شهادات SSL/TLS لتشفير البيانات أثناء النقل.

2. **استخدم الشبكات الخاصة الافتراضية (VPN)**: استخدم شبكة افتراضية خاصة (VPN) لتشفير حركة المرور على الإنترنت والحماية من الاعتراض، خاصة على شبكات Wi-Fi العامة.

3. **شبكات Wi-Fi الآمنة**: قم بحماية شبكات Wi-Fi بتشفير قوي (WPA3) وتجنب استخدام الشبكات العامة أو غير الآمنة في المعاملات الحساسة.

4. **التحديثات المنتظمة**: حافظ على تحديث جميع البرامج، بما في ذلك المتصفحات وأنظمة التشغيل وأدوات الأمان، للحماية من الثغرات المعروفة.

5. **تثقيف المستخدمين**: تدريب المستخدمين على التعرف على محاولات التصيد الاحتيالي، وتجنب الروابط المشبوهة، والتحقق من صحة المواقع الإلكترونية والاتصالات.

6. **مراقبة حركة مرور الشبكة**: استخدم أدوات أمان الشبكة لمراقبة وتحليل حركة مرور البيانات بحثاً عن علامات النشاط المشبوه أو الوصول غير المصرح به.

أدوات لمنع هجمات الرجل في الوسيط

يمكن أن تساعد العديد من الأدوات والتقنيات في منع هجمات MITM:

1. **أدوات أمن الشبكات**: يمكن استخدام أدوات مثل Wireshark لمراقبة حركة مرور الشبكة واكتشاف هجمات MITM المحتملة. تساعد هذه الأدوات في تحليل حزم الشبكة وتحديد الحالات الشاذة.

2. **شهادات SSL/TLS**: تأكد من أن موقعك الإلكتروني يستخدم شهادات SSL/TLS صالحة ومحدثة لحماية البيانات أثناء النقل. يجب أن تكون الشهادات صادرة عن مرجع مصدق (CA) حسن السمعة.

3. **أنظمة كشف التسلل (IDS)**: يمكن أن تساعد **أنظمة كشف التسلل** (IDS) في اكتشاف نشاط الشبكة غير المعتاد الذي قد يشير إلى هجوم MITM. تقوم أنظمة IDS بمراقبة حركة مرور الشبكة وإنشاء تنبيهات للسلوك المشبوه.

أمثلة على هجمات الرجل في الوسط الشهيرة

فيما يلي بعض الأمثلة البارزة على هجمات MITM:

- **اختراق شركة Equifax (2017)**: في عام 2017، كشف اختراق هائل للبيانات عن المعلومات الشخصية لـ 147 مليون شخص. على الرغم من أن الهجوم لم يكن حصريًا هجومًا من هجمات MITM، إلا أن المهاجمين استغلوا نقاط الضعف لاعتراض البيانات المتعلقة بالدرجات الائتمانية والسجلات المالية. أدى الاختراق إلى فقدان بيانات حساسة، بما في ذلك أرقام الضمان الاجتماعي والعناوين والسجلات الائتمانية.

- **هجوم ديجي نوتار (2011)**: وقعت هيئة إصدار الشهادات الهولندية DigiNotar ضحية لهجوم MITM في عام 2011 عندما اعترض القراصنة شهادات SSL. وقد سمح لهم ذلك بانتحال صفة المواقع الإلكترونية الآمنة، مستهدفين أكثر من

300,000 مستخدم لجوجل في إيران. اعترض المهاجمون الاتصالات الخاصة للضحايا، وكشفوا رسائل البريد الإلكتروني الحساسة والبيانات الشخصية.

- **هجوم فيسبوك MITM على فيسبوك (2013):** في عام 2013، تم الإبلاغ عن أن مستخدمي فيسبوك في سوريا كانوا ضحايا هجوم MITM. حيث قام القراصنة بإدخال شيفرة خبيثة في صفحة تسجيل الدخول إلى فيسبوك، مما سمح لهم بالتقاط **بيانات اعتماد تسجيل الدخول**. وبمجرد الدخول، تمكن المهاجمون من الوصول إلى الحسابات الشخصية والتلاعب بها.

هجمات حقن SQL: فهم الثغرات وطرق الحماية الفعالة

قواعد البيانات هي العمود الفقري لأي تطبيق ويب حديث. من معلومات المستخدمين وكلمات المرور إلى تفاصيل المنتجات والطلبات، كل شيء تقريباً يتم تخزينه واسترجاعه من قواعد البيانات. ولكن ماذا لو تمكن شخص ما من التلاعب بهذه القواعد؟ هذا هو بالضبط ما تفعله هجمات حقن SQL (SQL Injection)، والتي تُعد واحدة من أخطر وأكثر الثغرات شيوعاً [...]

ما هي هجمات حقن SQL؟

SQL (Structured Query Language) هي اللغة القياسية المستخدمة للتواصل مع قواعد البيانات. عندما تتفاعل مع موقع ويب (مثل تسجيل الدخول، أو البحث عن منتج، أو ملء نموذج)، فإن التطبيق يقوم بإنشاء أوامر SQL وإرسالها إلى قاعدة البيانات لاسترجاع أو تخزين المعلومات.

هجوم حقن SQL يحدث عندما يتمكن المهاجم من **إدخال أوامر SQL ضارة** في حقول الإدخال الخاصة بتطبيق الويب. بدلاً من أن يتم التعامل مع مدخلات المهاجم كبيانات عادية (مثل اسم المستخدم أو كلمة المرور)، يقوم التطبيق بمعالجتها كجزء من أمر SQL الفعلي الذي يتم تنفيذه في قاعدة البيانات. هذا يسمح للمهاجم "بالتحدث" مباشرة إلى قاعدة البيانات وتنفيذ أوامر لم تكن مقصودة.

كيف تعمل هجمات حقن SQL؟

لنفترض أن لديك موقعًا إلكترونيًا يسجل دخول المستخدمين باستخدام اسم المستخدم وكلمة المرور. قد يكون أمر SQL الذي يتم تنفيذه في الخلفية شيئًا كهذا:

SQL

```
SELECT * FROM Users WHERE Username = 'اسم_المستخدم_المدخل' AND Password = 'كلمة_المرور_المدخل';
```

إذا أدخل المستخدم اسمًا عاديًا وكلمة مرور، فإن الاستعلام يعمل بشكل طبيعي. ولكن ماذا لو أدخل المهاجم شيئًا مثل admin' OR '1'='1 في حقل اسم المستخدم؟ سيصبح الاستعلام كالتالي:

SQL

```
SELECT * FROM Users WHERE Username = 'admin' OR '1'='1' AND Password = 'كلمة_المرور_المدخل';
```

هنا، الشرط '1'='1' هو دائمًا صحيح. هذا يعني أن الاستعلام سيعيد جميع المستخدمين أو سيسمح للمهاجم بالدخول كمسؤول (admin) دون الحاجة إلى معرفة كلمة المرور!

هذا مثال بسيط، لكن هجمات SQL Injection يمكن أن تكون أكثر تعقيداً بكثير، مما يسمح للمهاجم بـ:

- **سرقة البيانات:** استخراج جميع البيانات من قاعدة البيانات.
- **تغيير البيانات:** تعديل أو حذف البيانات.
- **الوصول إلى النظام:** في بعض الحالات، يمكن استخدامها لتشغيل أوامر نظام التشغيل على الخادم.

أنواع هجمات حقن SQL

- **In-band SQLi :** حيث يستخدم المهاجم نفس قناة الاتصال لشن الهجوم وجمع النتائج (مثل المثال أعلاه).
- **Inferential SQLi (Blind SQLi):** لا يتم إرجاع البيانات مباشرة إلى المهاجم، ولكنه يستنتج معلومات حول قاعدة البيانات عن طريق مراقبة استجابات التطبيق (مثل التأخير في الاستجابة أو رسائل الخطأ).
- **Out-of-band SQLi :** يستخدم المهاجم قناة اتصال مختلفة لشن الهجوم وجمع النتائج.

عواقب هجمات حقن SQL

يمكن أن تكون العواقب وخيمة:

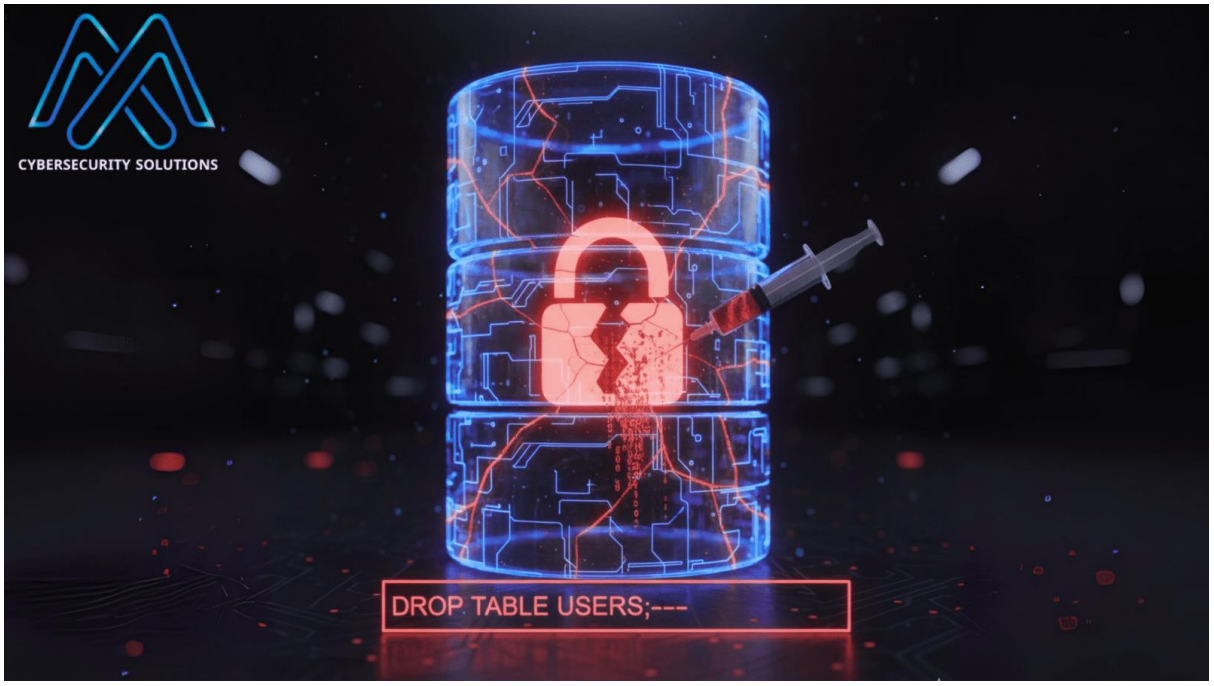
- **تسريب بيانات العملاء الحساسة:** مثل أرقام بطاقات الائتمان، ومعلومات الهوية، وبيانات شخصية.
- **الوصول غير المصرح به:** السيطرة الكاملة على تطبيق الويب أو حتى الخادم.
- **تشويه الموقع:** تغيير محتوى الموقع أو حقن محتوى ضار.
- **فقدان السمعة والثقة.**

كيفية الحماية من هجمات حقن SQL

لحسن الحظ، يمكن الوقاية من معظم هجمات حقن SQL من خلال ممارسات تطوير آمنة:

1. **العبارات المُحضّرة (Prepared Statements) والاستعلامات المُعمَّدة (Parameterized Queries):** هذه هي الطريقة الأكثر فعالية. بدلاً من دمج مدخلات المستخدم مباشرة في استعلام SQL، يتم تمريرها كمعلمات منفصلة، مما يمنع قاعدة البيانات من تفسيرها كجزء من أمر SQL.
2. **التطهير والتحقق من صحة المدخلات (Input Validation and Sanitization):** يجب التحقق من جميع مدخلات المستخدم للتأكد من أنها تتوافق مع التنسيق المتوقع وتطهيرها لإزالة أي أحرف خاصة أو أوامر SQL محتملة.
3. **امتيازات أقل (Least Privilege):** يجب أن تمنح حسابات قواعد البيانات امتيازات ضرورية فقط لأداء وظائفها، لا أكثر.
4. **تحديث البرامج:** تحديث جميع برامج قواعد البيانات وتطبيقات الويب بانتظام لإصلاح الثغرات المعروفة.

تعد هجمات حقن SQL تهديدًا خطيرًا يتطلب يقظة مستمرة من المطورين وخبراء الأمن. من خلال فهم آلياتها **وتطبيق أفضل ممارسات الحماية، يمكننا بناء تطبيقات ويب أكثر أمانًا وحماية بيانات المستخدمين.**


CYBERSECURITY SOLUTIONS
DROP TABLE USERS;---